

Reporte de simulaciones

Divier Jácamo Álvarez

Cetav La Libertad

Rol: Analista SOC L1

Fecha: viernes 06/03/26

Reporte Técnico de Simulaciones

La administración de datos sensibles en instalaciones de salud mental necesita sistemas electrónicos de historiales médicos, plataformas de telepsiquiatría y bases de datos que contengan información personal y diagnósticos psiquiátricos. La vulnerabilidad a ciberataques, como ransomware, robo de datos y accesos no autorizados, puede poner en peligro la privacidad de los pacientes y la continuidad del cuidado en este entorno, la creación de modelos de turnos para el SOC, junto con la categorización de incidentes y la fusión del monitoreo de la red y los puntos finales, es crucial para asegurar un funcionamiento resistente y una respuesta adecuada ante incidentes.

Este informe reúne los siguientes elementos:

Modelo de turnos del SOC.

Clasificación de incidentes según su gravedad.

Integración y correlación de eventos de red, sistemas y puntos finales.

Documentación, procedimientos operativos y métricas de rendimiento.

Marco Teórico

Centros de Operaciones de Seguridad

Un SOC es un cuerpo especializado en la supervisión constante de activos tecnológicos y en la gestión de incidentes relacionados con la ciberseguridad los analistas de SOC de Nivel 1 se ocupan de monitorear alertas, realizar un análisis inicial de eventos y escalar a Nivel 2 además, documentan de manera estructurada el SOC utiliza herramientas como Splunk e IBM QRadar para correlacionar eventos que provienen de firewalls, IDS/IPS, servidores clínicos y puntos finales.

Simulaciones de Seguridad

Las simulaciones permiten replicar incidentes sin poner en riesgo la operación real, evaluando la efectividad del SOC en la detección, análisis y respuesta. Los escenarios

que se simulan incluyen:

Ataques de ransomware.

Robo de datos clínicos.

Denegación de servicio.

Compromiso de credenciales administrativas.

Estas evaluaciones se alinean con el marco MITRE ATT&CK, que organiza tácticas y

técnicas de ataque.

Modelo de Turnos SOC

Modalidad Operativa

Se sugiere un modelo 8x5 con un guardia disponible para respuesta, dado que la mayor parte de las clínicas funcionan en horario laboral:

SOC L1: 08:00 am – 5:00 pm

SOC L2: 09:00 am – 6:00 pm

Guardia fuera de horario: 6:00 pm – 8:00 pm en turnos rotativos semanales, para incidentes críticos.

Incidentes críticos: ransomware activo, acceso no autorizado a historiales médicos, compromiso de servidores esenciales, fallas en dispositivos de seguridad perimetral.

El tiempo máximo de respuesta debe ser de entre 15 y 30 minutos.

Funciones por Nivel

SOC L1: supervisión de SIEM, análisis inicial, revisión de registros críticos, documentación y escalamiento.

SOC L2: investigación más profunda, análisis forense, contención de amenazas, ajuste de reglas de SIEM y mejora continua de los playbooks.

Procedimiento de Handoff

Se establece un traspaso diario de 15 minutos que abarca: incidentes activos, alertas

pendientes, ajustes de reglas, riesgos emergentes y recomendaciones para la
operación.

Clasificación de Incidentes

Se propone una categoría de incidentes según su severidad para priorizar recursos y
mejorar la respuesta:

Leve: sin daño ni compromiso de información confidencial.

Clínico: ligero retraso en la medicación.

SOC: intento de acceso bloqueado, correo sospechoso neutralizado.

Moderado: daño temporal que requiere intervención técnica o clínica.

Clínico: dosificación incorrecta, autolesión menor.

SOC: acceso interno no autorizado, interrupción temporal de sistemas.

Grave: amenaza a la vida, continuidad de la operación o confidencialidad.

Clínico: intento de suicidio, agresión física severa.

SOC: ransomware cifrando bases de datos, filtración de información sensible.

La validación interdisciplinaria a través de un comité técnico garantiza la coherencia y
trazabilidad.

Integración de Monitoreo de Red y Sistema

Eventos de Red.

Firewalls, IDS/IPS, switches, routers, DLP.

Eventos: intentos fallidos, tráfico irregular, escaneos, grandes transferencias.

Eventos de Sistema

Servidores clínicos, controladores de dominio, estaciones administrativas.

Logs: autenticación, creación de usuarios, ejecución de procesos y modificaciones críticas.

Correlación de Eventos

Normalización y mejora de logs.

Reglas de correlación: conexión lógica y temporal entre eventos, por ejemplo:

Múltiples intentos fallidos de autenticación + IP externa dudosa → posible ataque de fuerza bruta.

Transferencia masiva de datos + acceso fuera del horario habitual → posible exfiltración.

Escaneo interno + proceso no autorizado → posible movimiento lateral.

Rol SOC L1: validación preliminar, análisis contextual, escalamiento a SOC L2.

Caso Aplicado

Tráfico inusual desde la estación administrativa, firewall detecta un dominio malicioso, el servidor clínico anota un inicio de sesión en horario no habitual → activación del protocolo de respuesta ante posible exfiltración.

Integración de Monitoreo de Endpoints

Endpoints como estaciones de trabajo, servidores y laptops son cruciales en potenciales ataques.

Eventos monitoreados: ejecución de procesos sospechosos, cambios masivos en archivos, alteraciones de configuraciones y conexiones externas no autorizadas.

Los datos son enviados a SIEM para ser correlacionados con eventos de red y sistemas.

Beneficios: detección anticipada, disminución de falsos positivos, capacitación del SOC y desarrollo de habilidades analíticas.

Documentación y Procedimientos Operativos

Registro de alertas, análisis inicial, clasificación, escalamiento y bitácora de evidencia.

La documentación garantiza el cumplimiento normativo: protección de información médica, control de accesos, auditoría de cambios, retención y anonimización de datos.

Gestión de cambios: versión de reglas de correlación, actualización de firmas de

IDS/IPS y simulaciones documentadas cada trimestre.

Indicadores de Desempeño

Tiempo Medio de Detección

Tiempo Medio de Respuesta

Tasa de falsos positivos

Número de incidentes correctamente escalados

Estos KPIs permiten medir la madurez operativa del SOC y la efectividad de las simulaciones.

Coherencia de Resultados

Flujo lógico:

El informe sigue una estructura lógica: introducción → marco teórico → modelo de turnos → clasificación de incidentes → integración de monitoreo de red y endpoints → documentación y procedimientos → indicadores → conclusión.

Cada sección apoya a la anterior: por ejemplo, los turnos del SOC respaldan la habilidad de detectar y responder a incidentes clasificados.

Concordancia conceptual:

La conexión entre los turnos del SOC, la clasificación de incidentes y las simulaciones de monitoreo es evidente: los incidentes críticos se asignan de manera adecuada al turno de guardia y se documentan basándose en su gravedad.

El SOC de Nivel 1 se mantiene como el encargado de la supervisión inicial, validación de alertas, correlación y ascenso de incidencias al SOC de Nivel 2.

2. Validación de Procedimientos y Roles

Turnos SOC:

Los horarios y la superposición de turnos coinciden con la cobertura necesaria para incidentes críticos.

Las responsabilidades de L1 y L2 son complementarias y no se solapan inapropiadamente.

Clasificación de incidentes:

Las categorías Leve, Moderado y Grave están bien definidas y son coherentes con los ejemplos clínicos y de ciberseguridad.

La validación por parte de múltiples disciplinas garantiza la consistencia entre el impacto clínico y el digital.

Monitoreo de red y endpoints:

Las reglas de correlación están sincronizadas con eventos simulados y patrones de

MITRE ATT&CK.

Los flujos para normalizar, enriquecer y escalar las alertas están debidamente

documentados y son coherentes con el rol del SOC de Nivel 1.

3. Coherencia de Simulaciones y Resultados Esperados

Eventos simulados:

Los escenarios de ransomware, exfiltración de datos, accesos no autorizados y

movimiento lateral se presentan tanto en la red como en los endpoints.

La integración con SIEM asegura que los incidentes generen alertas correlacionadas,

lo cual es coherente con las prácticas de simulación del SOC.

Indicadores

MTTD, MTTR, tasa de falsos positivos y cantidad de incidentes escalados están en

relación directa con los procedimientos y la cobertura de los turnos.

No existen indicadores inconsistentes; todos son mensurables a partir de las

simulaciones descritas.

4. Coherencia Regulatoria y Ética

Protección de datos:

El uso de datos anonimizados y el aislamiento del entorno de simulación está

correctamente mencionados.

La documentación respalda el cumplimiento de normativas tanto internacionales como locales, en consonancia con la confidencialidad en clínicas de salud mental.

Documentación y trazabilidad:

Los procedimientos de recepción, análisis, clasificación y escalamiento de alertas son coherentes con los objetivos de trazabilidad y mejora continua.

La integración entre red, sistemas y endpoints garantiza que cada incidente pueda ser rastreado y validado.

Conclusiones

Importancia de la integración multidimensional:

La ejecución de simulaciones que combinan los modelos de turnos del SOC, la categorización de incidentes y la vigilancia de redes, sistemas y endpoints, representa un método integral para salvaguardar información clínica y mantener la operatividad en clínicas de salud mental esta fusión garantiza una colaboración efectiva entre los recursos humanos y tecnológicos, mejorando la detección, análisis y respuesta a incidentes críticos.

Efectividad del SOC Nivel 1 y Nivel 2:

Una clara delineación de funciones y obligaciones entre el SOC de Nivel 1 y Nivel 2 promueve un funcionamiento eficaz el SOC de Nivel 1 asegura el monitoreo continuo, la validación inicial de alertas y la documentación, mientras que el SOC de Nivel 2 se dedica a investigaciones avanzadas, análisis forense y optimización de controles técnicos. Este esquema refuerza la resiliencia operativa y disminuye el riesgo de errores o omisiones significativas.

Clasificación de incidentes y priorización:

La estructuración de incidentes en categorías Leve, Moderado y Grave, respaldada por un comité interdisciplinario, facilita la asignación de recursos y la toma de decisiones rápidas y fundamentadas se ha demostrado que los incidentes de ciberseguridad pueden impactar indirectamente en la atención clínica, por lo que la coordinación entre equipos técnicos y clínicos es crucial para asegurar la seguridad del paciente y la protección de datos sensibles.

Correlación de eventos y monitoreo continuo:

La unificación de los eventos de red, sistemas y endpoints en plataformas SIEM ayuda a identificar patrones de ataque sofisticados y a disminuir los falsos positivos. La normalización de registros, el enriquecimiento contextual y la aplicación de reglas de correlación, conforme al marco MITRE ATT&CK, permiten la detección temprana

de amenazas, mejorando el tiempo medio de detección y el de respuesta.

Documentación y cumplimiento normativo:

La documentación metódica de procedimientos, eventos y resultados de simulaciones asegura la trazabilidad, el cumplimiento de normativas nacionales e internacionales y simplifica las auditorías, tanto internas como externas además, refuerza la cultura de ciberseguridad en la institución y posibilita evaluar la madurez operativa del SOC a través de indicadores clave de desempeño.

Desarrollo continuo y sostenibilidad operativa:

Las simulaciones ofrecen un entorno seguro para la capacitación del personal del SOC, la evaluación de brechas y la mejora continua de procesos la planificación estratégica de turnos y la actualización constante de reglas de correlación garantizan la sostenibilidad operativa y la resiliencia institucional ante amenazas cibernéticas emergentes.

Recomendaciones generales:

Establecer comités interdisciplinarios para la revisión de incidentes y la validación de la gravedad.

Registrar formalmente todas las simulaciones, incidentes y modificaciones de reglas

de correlación.

Implementar procedimientos de triage para incidentes críticos que ocurren

simultáneamente.

Realizar revisiones periódicas de los indicadores de rendimiento para evaluar la

efectividad del SOC y optimizar el uso de recursos.

Referencias

Chamkar, S., Maleh, Y., & Gherabi, N. (2024). *Security Operations Centers: Use case best practices, coverage, and gap analysis based on MITRE adversarial tactics, techniques, and common knowledge*. *Journal of Cybersecurity and Privacy*, 4(4), 777–793.
<https://doi.org/10.3390/jcp4040036>

National Institute of Standards and Technology. (2022). *11 Strategies of a world-class cybersecurity operations center*. MITRE.
<https://www.mitre.org/sites/default/files/2022-04/11-strategies-of-a-world-class-cybersecurity-operations-center.pdf>

Reynolds, C. (2021, July 8). *Effective security monitoring: Building a robust SOC*. *ACE Journal*. <https://www.acejournal.org/2021/07/08/effective-security-monitoring>

ManageEngine. (2025). *¿Qué es un Security Operations Center (SOC)?*
<https://www.manageengine.com/latam/log-management/ciberseguridad/que-es-soc.html>

Shen, X., Li, Z., Burleigh, G., et al. (2024). *Decoding the MITRE Engenuity ATT&CK Enterprise evaluation: An analysis of EDR performance in real-world environments*. arXiv.
<https://arxiv.org/abs/2401.15878>